

SECURITY CONTROLS MATRIX

CompTIA Framework Classification (Categories vs. Functions)

Category	Preventive Stops before	Detective Identifies during/after	Corrective Fixes damage	Deterrent Discourages attacker	Compensating Alternative	Directive Mandates behavior
Managerial (Administrative)	• Background checks • Separation of Duties (SoD) • Risk Assessments	• Policy compliance audits • Reviewing access logs	• Incident Response Plans (IRP) • Disciplinary actions	• Acceptable Use Policy (AUP) • Threat of termination	• Policy exceptions • Documented risk acceptance	• Security policies • Regulatory frameworks (HIPAA, PCI)
Operational	• Security awareness training • Media sanitization • Change management	• Threat hunting • Manual log reviews (SOC ops)	• Executing disaster recovery • Re-imaging machines	• Routine phishing warnings • Visible security drills	• Increased manual monitoring of unpatched systems	• Standard Operating Procedures (SOPs)
Technical (Logical)	• Firewalls / ACLs • Encryption (AES/RSA) • MFA & Strong passwords	• IDS (Snort/Suricata) • SIEM alerts • Antivirus scans	• IPS (Active blocking) • Automated backups • Patch management	• SSH warning banners • Fake honeypots	• VLAN isolation for legacy systems (e.g. Win XP)	• Group Policy Objects (GPOs) • Conditional Access
Physical	• Fences & Bollards • Mantraps • Biometric locks	• CCTV Cameras • Motion sensors • RFID badge logs	• Fire suppression (FM-200) • UPS & Backup Generators	• "Guard Dog" signs • Visible security guards • Barbed wire	• Padlocks on unsecurable network cabinets	• Physical signage ("Employees Only")